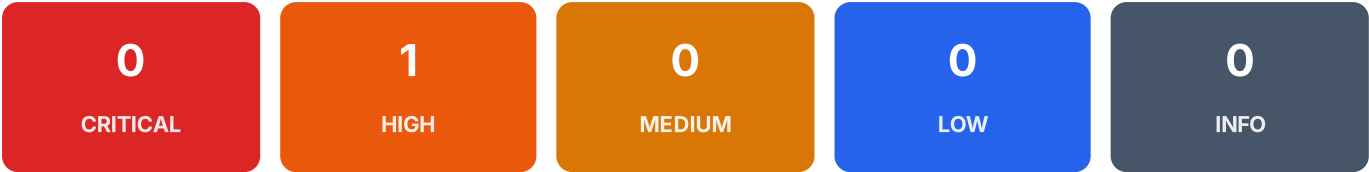


Security Assessment & Vulnerability Report

Target Asset: 127_0_0_1_8888

ASSESSMENT DATE	TOTAL CONFIRMED FINDINGS	ASSESSMENT SCOPE
2026-08-21 21:02:44	1 Flaws	Authorized Full-Surface



1. Executive Findings Matrix

Severity	Vulnerability Title	CVSS	CWE	Affected Endpoint
HIGH	IDOR Vulnerability Report	N/A	N/A	N/A

2. Detailed Technical Findings & Proof of Concepts

#1 — IDOR Vulnerability Report

INFORMATIONAL

Executive Summary

Vulnerability	IDOR (Insecure Direct Object Reference)
Affected Endpoint	/api/documents/102
Severity	High
Impact	Unauthorized access to sensitive data

Description

The `/api/documents/102` endpoint was identified as vulnerable to IDOR attacks. An unauthenticated or unauthorized user can directly access sensitive data by manipulating the `id` parameter in the API URL. This was validated using a proof-of-concept (PoC) Python script.

Steps to Reproduce

1. Send a GET request to `http://127.0.0.1:8888/api/documents/102`
2. Include Authorization headers if the application requires it.
3. Observe the response body and status code.
4. If the response contains sensitive or restricted data, the endpoint is vulnerable to IDOR.

PoC script:

```
import requests

url = "http://127.0.0.1:8888/api/documents/102"
headers = {
    'Authorization': 'Bearer <replace_with_valid_token_if_required>'
}
response = requests.get(url, headers=headers)

if response.status_code == 200:
    print("Potential IDOR found! Response:", response.text)
else:
    print("Access denied.", response.status_code)
```

Impact

Sensitive user or system data may be exposed to unauthorized users, leading to a compromise of confidentiality.

Remediation

1. Implement access control checks for user authorization and ownership verification at the backend.
2. Use session tokens or contextual metadata to ensure valid access permissions.
3. Regularly audit endpoints for direct object references.

Evidence

Detailed PoC and endpoint response are available in the Python script located at:

```
/home/ikhsan/Documents/Cybermes/reports/poc_idor.py .
```

3. Standalone Verification PoC Scripts

```
pocs/poc_idor.py
```